

2 Critical / High · 1 unfixed · Scanned 2026-06-28

1. Images Covered

Each image is identified by its immutable SHA256 digest. Tags are mutable and listed for convenience only.

Variant	Tag	Image @ Digest	Size
full	1.8.3	harbor.example.mil/acme/widget-api@sha256:3f1d9c0a8b7e6f5d4c3b2a1908f7e6d5c4b3a29180f7e6d5c4b3a29180f7e6d5	82 MB
airmark	1.8.3-airmark	harbor.example.mil/acme/widget-api@sha256:a1b2c3d4e5f6079889aabbccddeeff00112233445566778899aabbccddeeff00	31 MB

full — complete runtime image. airmark — minimized distroless variant for air-gapped & edge use.

2. Harbor Vulnerability Scan Results

CRITICAL	HIGH	MEDIUM	LOW	UNKNOWN	TOTAL
0	2	4	9	1	16

CVE	Severity	Component @ Version	Fixed Version
CVE-2024-45491	HIGH	libexpat 2.5.0-1	2.6.3-1
CVE-2024-6119	HIGH	openssl 3.0.13-1	3.0.14-1

Critical and High only; Medium and Low are in the attached scan JSON (\$7).

3. VEX — Unfixed Critical / High

One assertion per unfixed Critical/High — not-affected with justification, or a remediation date. POA&M-ready; statuses follow OpenVEX.

CVE-2024-45491

Justification

Remediation by

vulnerable_code_not_in_execute_path

2026-07-31

NOT AFFECTED full

4. Software Bill of Materials (SBOM)

Format	CycloneDX (1.6 JSON)
Components inventoried	214 components (118 OS pkgs, 96 application)
Attached as	in-toto attestation (predicate cyclonedx)
SBOM digest	sha256:9988776655443322110099887766554433221100998877665544332211009988

Answers component-presence questions (e.g. log4j, openssl) without re-scanning. Attached as an in-toto attestation, retrievable from the registry.

5. Build Provenance & Signature

Built by	GitHub Actions (hosted runner, OIDC)
Workflow	.github/workflows/release.yml@refs/tags/v1.8.3
Source	acme/widget-api @ c0ffee1
Run	actions/runs/9876543210 · SLSA Provenance v1
Signed with	cosign (keyless / GitHub OIDC, repo=acme/widget-api)
Transparency log	https://rekor.sigstore.dev (index 148820391)

```
cosign verify \  
  --certificate-identity-regexp '^https://github.com/acme/widget-api' \  
  --certificate-oidc-issuer https://token.actions.githubusercontent.com \  
  harbor.example.mil/acme/widget-api@sha256:3f1d9c0a...e6d5
```

Verify against the digest in §1 to confirm the scanned image is the one built here.

6. Image Hardening

- ✓ Runs as non-root (UID 65532, no setuid binaries)

✓ Chainguard (Wolfi) distroless base, daily-rebuilt

✓ Minimal attack surface — airmark variant is 31 MB
- ✓ No shell and no package manager in the image

✓ Read-only root filesystem compatible

✓ No secrets or build tooling in final layers

7. Scan Metadata — As Of

Scan date	2026-06-28	Trivy vuln DB	ver 2, updated 2026-06-28 06:14 UTC
Harbor	Harbor v2.11.1	Report prepared by	J. Rivera, Product Security Lead, ACME Platform
Scanner	Trivy 0.52.0	Contact	security@acme.example

Point-in-time scan; valid only for the digests in §1, as of 2026-06-28.